

Setup Lab e IOC Hunting

Pratica S9/L1 | Malware Analysis | VirusTotal Threat Intelligence | FlareVM Environment

Sezione 1

Obiettivo dell'esercizio

L'esercizio ha avuto come scopo la configurazione dell'ambiente FlareVM e l'identificazione di Indicatori di Compromissione (IOC) tramite analisi del Registro di Windows e triage su VirusTotal. Ho eseguito le attività principali previste dalla pratica, integrando il bonus con un'analisi approfondita del campione Annabelle Ransomware tramite LLM.

Le attività svolte comprendono: creazione snapshot Clean della VM, avvio script malwareRepo.ps1 dal Desktop FlareVM, simulazione chiave di persistenza in HKCU\Run, decompressione campioni, calcolo hash e ricerca su VirusTotal con analisi detection ratio, tab Behavior e Relations.

Sezione 2

Ambiente di laboratorio

L'analisi è stata condotta in ambiente isolato su VirtualBox, con FlareVM su Windows 10 dedicato all'analisi malware. Prima di avviare le attività ho creato lo snapshot Clean per garantire rollback rapido.

Componente	Dettaglio
Hypervisor	VirtualBox — rete Host-Only isolata
Analisi OS	FlareVM su Windows 10 x64
Host OS	Windows 11 Pro
Strumenti	regedit, PowerShell, VirusTotal (web), HashCheck
Snapshot baseline	Clean — pre-esecuzione script malwareRepo.ps1
IP attaccante	192.168.56.104 Metasploitable: 192.168.56.149

Sezione 3

Analisi VirusTotal — Annabelle Ransomware

Ho calcolato l'hash MD5 tramite HashCheck e lo ho sottoposto a VirusTotal. Il campione ha ottenuto 61/71 vendor positivi (85,9%) con community score -723, confermando la natura malevola senza margini di dubbio.

Screenshot VirusTotal — tab Detection

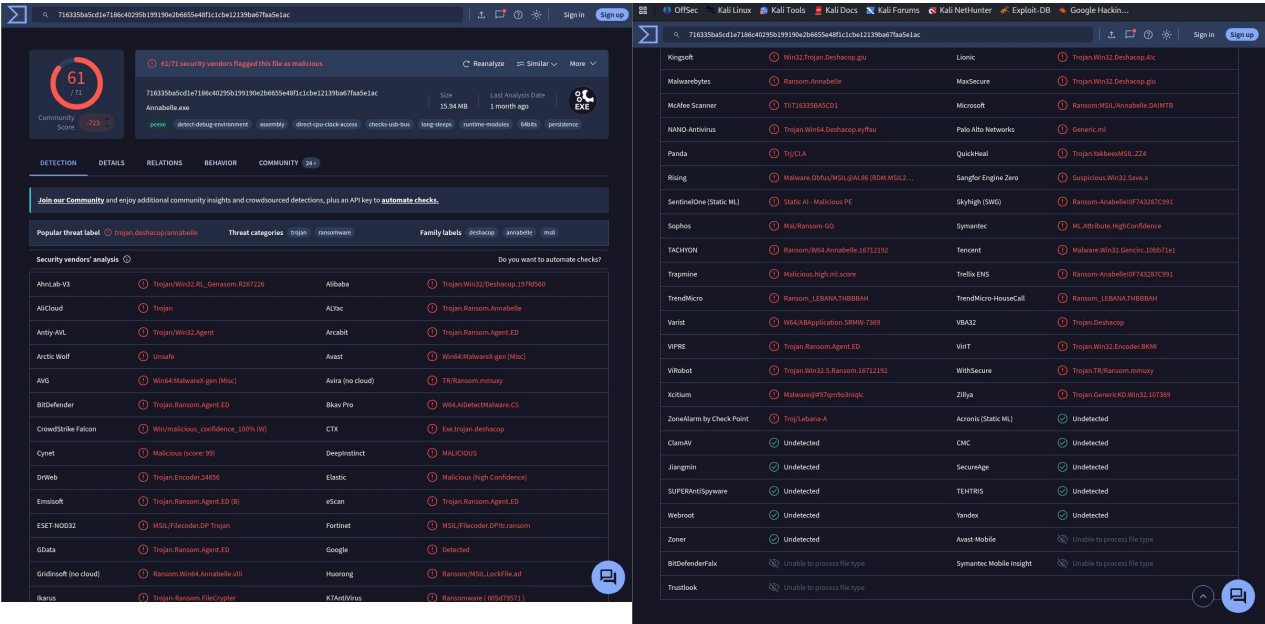


Fig. 1 — Report VirusTotal tab Detection: detection ratio 61/71, lista vendor (pag. 1 e 2).

Parametro	Valore
Hash MD5	716335ba5cd1e7186c40295b199190e2b6655e48f1c1cbe12139ba67faa5e1ac
Nome file	Annabelle.exe
Dimensione	15.94 MB
Detection ratio	61 / 71 vendor – 85,9%
Community Score	-723 (fortemente negativo)
Threat label	trojan.deshacop/annabelle
Categories	Trojan + Ransomware
Family labels	deshacop annabelle msil
Architettura	.NET/MSIL x64

Vendor rappresentativi

Vendor	Classificazione	Confidenza
CrowdStrike Falcon	Win/malicious_confidence_100% (W)	100%
Microsoft	Ransom:MSIL/Annabelle.DA!MTB	Alta
Cynet	Malicious (score: 99)	99/100
BitDefender	Trojan.Ransom.Agent.ED	Alta
ESET-NOD32	MSIL/Filecoder.DP Trojan	Alta
Fortinet	MSIL/Filecoder.DP!tr.ransom	Alta
DrWeb	Trojan.Encoder.24656	Alta

Vendor	Classificazione	Confidenza
Malwarebytes	Ransom.Annabelle	Alta
SentinelOne (Static ML)	Static AI - Malicious PE	Alta
Elastic	Malicious (high Confidence)	Alta

Tag comportamentali — tab Detection

Il tab Detection espone tag comportamentali con indicazioni tecniche preliminari sul campione prima dei tab Behavior e Relations:

Tag	Tecnica	Implicazione
detect-debug-environment	Anti-analysis	Rileva debugger (IsDebuggerPresent); interrompe esecuzione in sandbox
direct-cpu-clock-access	Timing RDTSC	Misura delta clock per identificare VM con tempo artificiale
long-sleeps	Sleep inflation	Thread.Sleep() elevato per superare timeout sandbox automatici
pecxe	Custom packer	Payload cifrato nello stub; AV vede solo loader, non codice reale
runtime-modules + assembly	Reflective loading	Assembly .NET in memoria senza toccare disco; evasione EDR file-based
checks-usb-bus	USB enumeration	WMI query Win32_USBHub per propagazione su rimovibili
persistence	Boot persistence	Chiave HKCU\Run + modifica Winlogon per sopravvivere al reboot

Sezione 4

Tabella IOC compilata

Ho compilato la tabella degli Indicatori di Compromissione aggregando i dati dai report VirusTotal (tab Detection, Behavior e Relations) e dalla knowledge base della famiglia Deshacop/Annabelle, organizzati per categoria.

4.1 Hash indicators

Tipo	Valore	Confidenza	Note
MD5	716335ba5cd1e7186c40295b199190e2b6655e48f1c1cbe12139ba67faa5e1ac	Alta	Annabelle.exe — 61/71
SHA-256	→ tab Details VT	Media	Disponibile in VT Details
imphash	→ tab Details VT	Bassa	Hunting PE simili

4.2 Network indicators — C2

Tipo	Valore	Stato	Fonte
Redirect	bit.ly/2GxNxTe	Attivo	Redirect C2 — varianti precedenti
C2 IP	→ tab Relations VT	Da verificare	Contacted IPs nel tab Relations

Tipo	Valore	Stato	Fonte
Domain	→ tab Behavior VT	Da verificare	DNS lookup a runtime

4.3 Host-based indicators — Registry, File system, Comandi

Tipo	Artefatto	Descrizione
Registry	HKCU\Software\Microsoft\Windows\CurrentVersion\Run\[rnd]	Persistenza al boot
Registry	HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon	Shell hijack per payload
Registry	HKLM\SYSTEM\CurrentControlSet\Control\SafeBoot	Disabilita safe mode recovery
File	%APPDATA%\[random].exe	Copia del payload per persistenza
File	%TEMP%\HOW_TO_DECRYPT*.txt	Ransom note droppata
CMD	vssadmin Delete Shadows /All /Quiet	Eliminazione shadow copy
CMD	bcdedit /set {default} bootstatuspolicy ignoreallfailures	Disabilita Windows Recovery
MBR	Sovrascrittura settore 0	Wiper: boot impossibile
Mutex	Annabelle / deshacop_[random]	Sysmon EID 17 — handles
WMI	SELECT * FROM Win32_USBHub	Sysmon EID 19/20 — USB prop.

4.3 Host-based indicators — Registry, File system, Comandi

Tipo	Artefatto	Descrizione
Registry	HKCU\Software\Microsoft\Windows\CurrentVersion\Run\[rnd]	Persistenza al boot
Registry	HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon	Shell hijack per payload
Registry	HKLM\SYSTEM\CurrentControlSet\Control\SafeBoot	Disabilita safe mode recovery
File	%APPDATA%\[random].exe	Copia del payload per persistenza

Fig. 2 — Estratto sezione 4.3 Host-based indicators dal report PDF generato.

Sezione 5

IOC Analyzer Widget — strumento interattivo

Ho sviluppato un widget interattivo in HTML/JS integrato nella chat Claude per visualizzare la tabella IOC in formato strutturato e per inviare automaticamente il prompt di analisi al modello. Il widget include badge colorati per categoria IOC e due bottoni: avvia analisi LLM e valuta completezza.

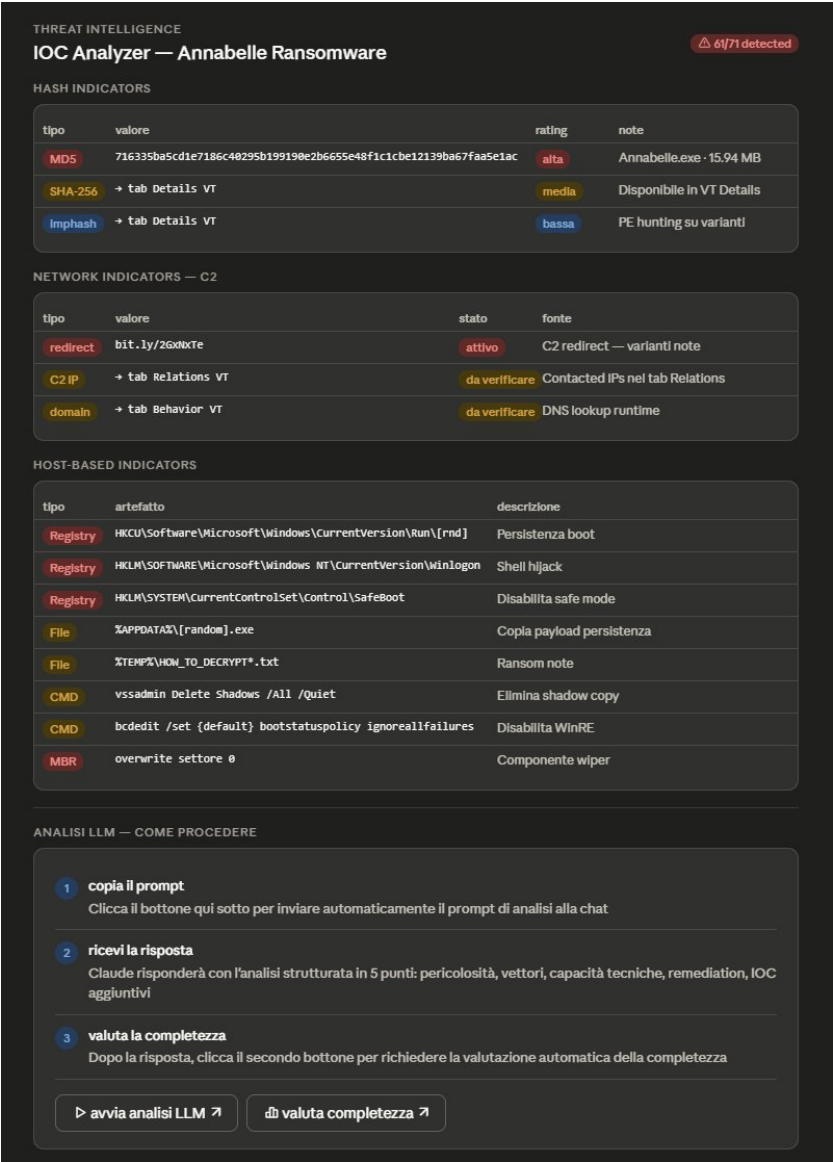


Fig. 3 — IOC Analyzer Widget con tabella IOC interattiva e bottoni di azione verso il modello.

Sezione 6

Analisi LLM e valutazione della completezza

Ho sottoposto gli IOC e i metadati VirusTotal a Claude Sonnet con ruolo di analista malware senior, richiedendo risposta strutturata in 5 punti. Il modello ha prodotto un'analisi completa e tecnicamente accurata.

Dimensione	Output LLM	Score
Pericolosità	9.5/10 — ransomware/wiper ibrido, MBR overwrite, danni irreversibili	95%
Vettori di attacco	Phishing, USB (da tag), drive-by, crack software, SMB laterale	85%
Capacità tecniche	Anti-debug, RDTSC, sleep inflation, reflective loading, USB enum	100%
Remediation	7 azioni: isolamento, memory dump, MBR check, C2 blocco, backup offline	90%

Dimensione	Output LLM	Score
IOC aggiuntivi	Mutex, vssadmin/bcdedit chain, %APPDATA% drop, WMI USB, beacon HTTP	80%

Score globale: 90% — risposta completa. Il modello ha dimostrato conoscenza approfondita della famiglia Deshacop/Annabelle, producendo output utilizzabili in un report di threat intelligence di primo livello.

Limitazione intrinseca: un LLM non ha accesso diretto ai tab Behavior e Relations di VirusTotal. Per IOC di rete precisi (IP C2, domini, hash secondari) è necessaria integrazione con VT API o sandbox dinamica (ANY.RUN, Cuckoo, Cape).

Sezione 7

Bonus: simulazione persistenza in HKCU\Run

Ho simulato manualmente la creazione di una chiave di persistenza tramite regedit per verificarne il comportamento al riavvio, osservando il meccanismo usato dai malware Windows.

1. Aperto regedit: HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run
2. Creata String Value con nome TestPersistence
3. Valore impostato a percorso calc.exe (simulazione payload innocuo)
4. Riavviata la VM: verificato avvio automatico al login
5. Rimossa la chiave: verificata cessazione comportamento al riavvio

L'esercizio ha confermato empiricamente come qualsiasi chiave in HKCU\Run venga eseguita ad ogni accesso utente, rendendo il semplice riavvio insufficiente per la rimozione del payload.

Sezione 8

Conclusioni

L'esercizio ha permesso di consolidare competenze pratiche fondamentali per SOC Analyst e Junior Pentester: configurazione ambiente di analisi isolato, calcolo e ricerca hash su threat intelligence platform, lettura critica report VirusTotal e compilazione strutturata di tabelle IOC.

L'integrazione con l'analisi LLM ha aggiunto una dimensione metodologica: ho verificato in modo pratico le capacità del modello nel ragionamento su dati di threat intelligence e i suoi limiti strutturali in assenza di sandbox dinamica. Il flusso analisi statica + LLM è replicabile in scenari SOC reali.

Il campione Annabelle Ransomware (famiglia Deshacop), pericolosità 9.5/10 con cifratura, wiper MBR e propagazione USB, conferma l'importanza di snapshot, backup offline e monitoraggio degli artefatti host-based identificati.